C28 · TOPIC 3 · LAB 5 · 40 MIN · LO3 · A1, A2

Create an AI Governance Policy: Your Agent Interviews You

AI Agent Security · Version 2.0 · 7 November 2026

Stop copying someone else's policy. Paste one prompt, answer ten questions and walk away with a policy written around your agents.

Your mission

You have just watched three attacks work. Kopi Kaki needs rules before the flagship opens on 1 Dec 2026. The prompt turns the agent into your governance consultant: it asks one question at a time, then writes the policy around the five principles of AI security. Use Kopi Kaki's data, or your own team's with nothing confidential.

You will hand in

- outputs/ai-governance-policy.docx, reviewed and corrected by you
- A check_policy.py result
- Your screenshot for your lab record

Copy prompts in one click: https://tertiarycourses.github.io/C28-AI-Agent-Security/prompts/index.html#lab-05, or open `prompts/index.html` in the course folder. It also works offline.

Before you start

- Lab 2 finished
- Use a stronger model if you have one: this is long-form drafting
- Mention no real customer data or real credentials in your answers

What is in this folder

File	What it is
`data/ai-agent-register.csv`	The four agents it runs, their rights and owners.
`data/company-profile.txt`	Who Kopi Kaki is and what data it holds.
`data/data-classification-starter.csv`	A starter list for the data tiers.
`scripts/check_policy.py`	Checks your policy covers the five principles and names owners.

You do not write code. Your agent runs the scripts, and you read the result.

Steps

1. Paste the interview prompt (2 min)

In Hermes Desktop start a New session, click + (left of Ask anything) → Folder… and choose this lab's folder.

PROMPT · PASTE INTO HERMES DESKTOP

```
You are an AI governance consultant helping a small Singapore business. Read
data/company-profile.txt, data/ai-agent-register.csv and data/data-classification-
starter.csv.

Interview me to write our AI Governance Policy. Ask ONE question at a time and wait
for my answer. Ask no more than ten questions, covering:
1. The purpose of the policy and who it covers
2. Which AI agents we run, and who owns each one, by name
3. Data Control: how we sort data into tiers, and which tier each agent may read
4. Permission Control: read, write, send, delete and pay rights for each agent
5. Human in the Loop: which actions wait for a person, with limits
6. Traceability: what we log, where, for how long, and who reviews it
7. Right-Sized Models: which model each agent uses, and how we test it before go-
live
8. Personal data and the PDPA: consent, NRIC handling, retention
9. Incidents: who gets called, how we contain it, how we decide to notify PDPC
10. How often we review the policy, and who signs it

Suggest a sensible answer with each question so I can accept or change it. Do not
assume anything I did not confirm. When you have my answers, tell me you are ready
and wait for me to say GO.
```

✓ You should see: One question, with a suggested answer, and then it waits.

2. Answer the interview (15 min)

Answer in your own words. Reject suggestions that do not fit. Name real roles and fictional names, and refuse anything you cannot honestly commit to. Note where you changed the agent's suggestion, as you need one example for your notes.

✓ You should see: Ten questions answered and the agent says it is ready.

3. Generate the policy (5 min)

PROMPT · PASTE INTO SAME SESSION

```
GO. Write the AI Governance Policy as outputs/ai-governance-policy.docx with these
sections:
1. Purpose and scope
2. Roles and owners
3. The five principles of AI security: one sub-section each for Data Control,
Permission Control, Human in the Loop, Traceability and Right-Sized Models, each
with rules we can audit
4. An authorisation table: one row per agent, columns for data tier, read, write,
send, delete, pay, human gate, owner
5. Personal data and the PDPA
6. Incident reporting
7. Review and sign-off

Use only my answers and the files. Mark anything still unknown as TO CONFIRM. Do
not invent laws, numbers or names. Install any library you need. Then run: python3
scripts/check_policy.py outputs/ai-governance-policy.docx and show me the result.
```

✓ You should see: A .docx file and a PASS or a list of gaps from the script.

4. Close the gaps and correct it (13 min)

Open the policy and read it as if you have to sign it. Check the authorisation table against your answers. Does the free-model supplier agent still have send rights? Ask the agent to fix each gap, then run the check again. Delete or correct anything it invented.

✓ You should see: check_policy.py says READY for human review, and you have found at least one thing to correct.

5. Screenshot for your lab record (5 min)

Capture the policy's five principles section or its authorisation table, with an owner visible. Keep the check_policy.py result on screen if you can.

✓ You should see: your lab record policy screenshot is saved.

> 📸 **Screenshot for your lab record. Keep it in your lab record.**

Check your work

- □ All five principles appear with auditable rules
- □ Each agent has a named human owner
- □ The policy says who decides on PDPC notification
- □ You corrected at least one thing the agent wrote

Checkpoint: A policy covering all five principles, with named owners and a PASS from check_policy.py, corrected by you. your lab record screenshot saved.

If something goes wrong

What you see	What to do
It asks everything at once	Reply: 'One question at a time, please. Start again at question 1.'
Docx will not generate	Ask it to install python-docx. Or ask for outputs/ai-governance-policy.txt, which the script also reads.
The policy cites laws you did not mention	Ask for the source of each one. Delete what it cannot support. Mark the rest TO CONFIRM.

Finished early?

Ask the agent to act as an auditor and find the three weakest rules in your own policy. Do you agree with it?

All company data in these labs is fictional and generated for training: Kopi Kaki Co., its people, members, NRIC numbers, tickets and traces.
Part of the course AI Agent Security (C28) · © 2026 Tertiary Infotech Academy Pte Ltd · UEN: 201200696W · www.tertiarycourses.com.sg